INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — Unitree Go2 EDU · Dört Bacaklı Mobil Robot

Şablon: PaketPro 3000 sürümü. Sorular gerçek bir makine olan Unitree Go2 EDU'ya uyarlanmıştır.
Çalışma akademik değerlendirmedir; kılavuz/CVE bilgisi [K]/[CVE], varsayımlar [V] olarak işaretlidir.

Ad Soyad: Sena Köse · 235542006 **Grup: B Şubesi | Tarih: 22.10.2026**

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

Bu dosyada: Kapak + LAB 1–4 (5 sayfa). LAB 5–7 ders ilerledikçe eklenecek.

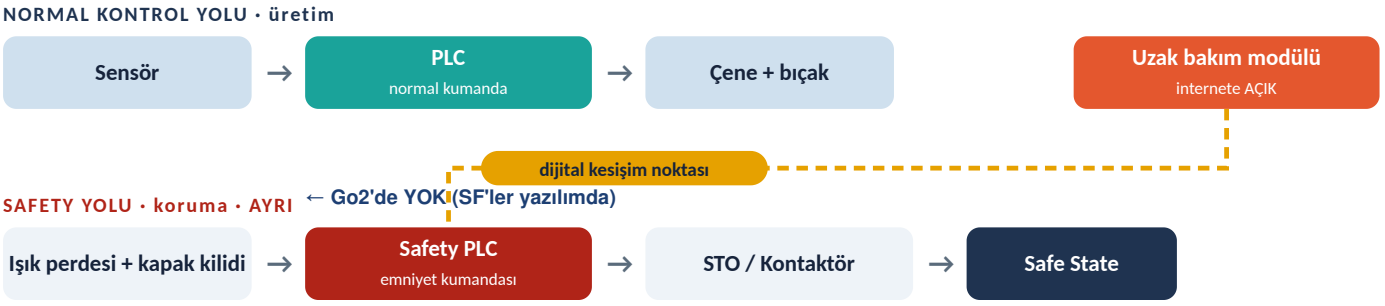
LABORATUVAR 1 · PAKETPRO SÜRÜMÜ · Unitree Go2 EDU

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad Sena Köse · 235542006 | Grup B Şubesi | Tarih 22.10.2026

PaketPro bağlamı: Sıcak yapıştırma çenesi ve film kesme bıçağı el/parmak için ciddi tehlikedir; koruma **ışık perdesi + kapak kilidi → Safety PLC → STO** zinciridir. Ve bu makinenin **internete açık bir uzak bakım modülü** vardır — sorular oraya gidecek.



Makine: Unitree Go2 EDU (kampüs devriye / araştırma robotu)

Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

15 kg gövdenin 5 m/s'ye kadar hızla insana **çarpması** (düşme, kırık); eklemler arasında (≈45 N·m tork) el/parmak **sıkışması**; merdiven/rampada **devrilip** yanındakine çarpması; hasarlı Li-ion bataryanın (≈430 Wh) **yanması**.

2 Safety function (emniyet fonksiyonu) hangisidir?

SF-1 acil durdurma "Damping" (kumandada L2 uzun + B, motorlar serbest) · **SF-2** LiDAR engel algılama (varsayılan açık) · **SF-3** hız sınırı (normalde ≤3,7 m/s) · **SF-4** yere çökme (Low Down) · **SF-5** denge koruması.

3 Safety-related control system nerede? Şemada işaretleyin.

Go2'de **ayrı bir safety-related kontrol sistemi yok**: bütün emniyet fonksiyonları normal hareketi yöneten yazılımın içinde (dahili bilgisayar 192.168.123.18 + MCU 192.168.123.161). Şemadaki alt "SAFETY YOLU" Go2'de boş kalıyor.

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretimi yönetir; Safety PLC ayrı ve yedekli kanalla, normal yazılım çökse bile makineyi güvenli duruma götürür. Go2'de bu ayrım **yok**: acil durdurma da normal komutlarla aynı yazılım yolundan geçiyor (kılavuz bile "bir acil durdurma kurun" diyor).

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

Güvenilirlik riskle orantılı olsun diye. Koridorda çarpma: S2 (ciddi) · F2 (insanlar sık) · P2 (kaçmak zor) → ISO 13849'a göre acil durdurma için **PLr d**. Tek kanallı bir yazılım fonksiyonunun bunu sağladığına dair belge yok. [V]

6 Safe state (güvenli durum) nedir?

Motor enerjisinin kesilip robotun **yere çökmesi** (Damping / Low Down). Ama robot hızlı koşarken ani damping yuvarlanma ve devrilmeye yol açabilir → güvenli durum her an güvenli değil; önce yavaşlayıp sonra çökmek gerekir. [V]

7 Safety function hangi dijital bağımlılıklara sahip?

SF-1 → el kumandası ve telsiz bağlantısı · SF-2 → LiDAR ve yazılım ayarı (kumandada **Y'ye 3 sn basınca kapanıyor**) · SF-3 → firmware ("Running" modu 5 m/s'ye çıkarıyor) · SF-5 → yüksek seviye kontrol modu · hepsi dahili bilgisayarın bütünlüğüne ve Unitree'nin OTA güncelleme zincirine bağlı.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

BLE/Wi-Fi yapılandırma yolundan root (**CVE-2025-35027**) → SF-2 kapatılır, Running moduna geçilir (SF-3 aşılır); alt seviye kontrole geçilince SF-5 tamamen kalkar; root yazılım kumandadan gelen damping komutunu yok sayabilir → **SF-1 çalışmaz** (bağımsız donanım yolu yok); sahte firmware (CVE-2026-1442) bunları kalıcı yapar. Ek kapı: kılavuzda yazan varsayılan **unitree** SSH hesabı. [V — test edilmedi]

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · PAKETPRO SÜRÜMÜ · Unitree Go2 EDU

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad Sena Köse · 235542006 | Grup B Şubesi | Tarih 22.10.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi Go2 karşılıkları: Üretim PLC→MCU · Emniyet PLC'si→**yok** · HMI port 80→web arayüzü port 9000 · uzak bakım modülü→4G/eSIM + Unitree bulutu · Wi-Fi AP→robotun kendi AP'si · USB→arka Ethernet/USB portları · admin/admin→kılavuzda yazan **unitree** SSH hesabı

Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · motor sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Z0 Harici: Unitree bulutu (OTA, LLM), 4G/eSIM, internet · **Z1 Kampüs ağı:** kampüs Wi-Fi, öğrenci/ofis cihazları · **Z2 Operatör/bakım:** Go uygulaması (telefon), araştırmacı PC'si, el kumandası · **Z3 Robot kontrol:** dahili bilgisayar (ROS 2, web 9000), MCU, LiDAR/kamera, motorlar, dahili router.

2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Karşılığı 4G/eSIM + bulut bağlantısı: robotun içinde (Z3) ama doğrudan internete (Z0) çıkıyor, kampüs güvenlik duvarını atlıyor. **Kalamaz**: Z3↔Z0 conduit'siz geçiş. Gereksizse kapatılmalı, gerekliyse kontrollü çıkış + izleme; yönetim sadece VPN/jump server'dan.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

C1 Z1↔Z3 SSH/yönetim: kişisel hesap, ara sunucu, kayıt · **C2** Z2↔Z3 BLE eşleştirme/Wi-Fi ayarı: yalnız yetkili bakımda açık, firmware sürümü · **C3** Z0→Z2→Z3 OTA: kaynak/bütünlük doğrulama, onaylı sürüm, sonrasında SF testi · **C4** Ethernet portu: fiziksel erişim, onaylı cihaz · **C5** 4G Z3↔Z0: gereksizse kapat · **C6** kumanda→Z3: yetkili kumanda, bağlantı kaybı davranışı.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — kampüs ağı robota doğrudan SSH yapamasın; yalnız onaylı servis açılır.
Tünel?	Açık / VPN	**VPN** — kampüs dışından; giriş noktası denetlenir. VPN üyeliği robot yetkisi vermez.
Kimlik?	Parola / MFA	**MFA** — erişim geçidinde; kılavuzda yazan varsayılan parola tek başına yetmez.
Hesap?	Paylaşılan / Kişisel	**Kişisel** — ortak **unitree** hesabı yerine; kim ne yaptı izlenebilir olsun.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** — kim, hangi robota, ne zaman, hangi onayla bağlandı.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — sadece onaylı süre boyunca açık; kalıcı bakım kapısı olmaz.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Sena Köse · 235542006 | Grup B Şubesi | Tarih 22.10.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

PaketPro'nun kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: çene/bıçakta el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
R-01 Meraklı içeriden: kampüs kullanıcısı → kampüs Wi-Fi + ortak/varsayılan **unitree** SSH hesabı → hız/engel ayarını değiştirir → SF-2/SF-3 devre dışı → robot koridorda kişiye çarpar (düşme, kırık).	2	3	2	12	Yüksek S=3 insan zararı
R-02 Hedefli: yakındaki saldırgan → Bluetooth/BLE Wi-Fi ayarı (CVE-2025-35027) → root → alt seviye kontrol, SF-5 denge kalkar → robot merdiven/rampa yanında devrilir, yanındakine çarpar.	2	3	2	12	Yüksek S=3 insan zararı
R-03 Tedarik zinciri: güncelleme zincirine müdahale → OTA yolu (CVE-2026-1442) → değiştirilmiş firmware kabul edilir → SF-1 durdurma bozulur → eklem yakınındaki el/parmak sıkışır.	1	3	1	3	Düşük (3) → S=3 kuralı: öne alındı

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

R-01 (12, Yüksek) — R-02 ile aynı skor ama kapısı (kılavuzda yazan varsayılan SSH hesabı) firmware sürümüne bağlı değil ve kampüs ağındaki herkesin ulaşabileceği yerde; zincir koridordaki bir kişinin ağır yaralanmasıyla bitiyor.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Evet, **R-03**: 1×3×1 = 3 (Düşük) ama kalıcı yaralanma ihtimali var. Risk Register'da **"S=3 / insan zararı — öncelikli inceleme"** bayrağı taşır; sayısal sınıfı değişmez ama Yüksek grubun hemen ardından listelenir (R-01 → R-02 → R-03).

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · PAKETPRO SÜRÜMÜ · Unitree Go2 EDU

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad Sena Köse · 235542006 | Grup B Şubesi | Tarih 22.10.2026

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: uzak bakım modülü bugün internete DOĞRUDAN açık.

Araştırmacı PC / telefon → kampüs Wi-Fi → robota doğrudan SSH (ortak **unitree** hesabı, kılavuzdaki varsayılan parola) → dahili bilgisayar → MCU → motorlar. BLE eşleştirme açık, 4G/eSIM kampüs duvarını atlıyor, OTA buluttan doğrudan. Ara nokta yok · MFA yok · kayıt yok · sürekli açık · emniyet aynı yazılımda.

HEDEF (beş ilkeyle yeniden tasarlayın)

Kişisel cihaz → (dışarıdan) **VPN** → **MFA** → **jump server** (oturum kaydı) → ayrılmış yönetim ağı → robot SSH, **kişisel hesap** + en az yetki. Erişim **varsayılan kapalı**, onaylı süre kadar açık. BLE yalnız bakımda; 4G kapalı/kontrollü; OTA onaylı pencerede + SF testi. + Ağdan bağımsız durdurma.

Görev B — functional safety köprüsü

1 Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

Evet, etkilenir. Go2'de SF-1…SF-5 saldırıya açık dahili bilgisayar/MCU yazılımının içinde, bağımsız safety yolu yok. Root alan saldırgan engel algılamayı kapatabilir, hızı açabilir, damping komutunu yok sayabilir. VPN/MFA/jump server sadece girme olasılığını düşürür.

2 Işık perdesi zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

Go2'de ışık perdesinin karşılığı LiDAR engel algılama + kumanda acil durdurma zinciri. SSH/4G/OTA bakım yolundan gelen hiçbir komut veya ayar engel algılamayı, hız sınırını ya da acil durdurmayı kapatamamalı; bu ayarlar yalnız yerinde, onaylı ve kayıtlı değişmeli; bakım yolu ele geçirilse de durdurma zinciri çalışmaya devam etmeli (**PLr d**).

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.